Figure 12.1 How the OIDC/OAuth2 roles are assigned to the entities in the Polar Bookshop architecture

Edge Service can access downstream applications on behalf of the user through an Access Token issued by Keycloak during the OIDC authentication phase. In this section, you'll see how to configure Spring Cloud Gateway in Edge Service to use the Access Token whenever a request is routed to Catalog Service and Order Service.

In the previous chapter, we defined two users: Isabelle has both the employee and customer roles, while Bjorn has just the customer role. In this section, you'll also learn how to include that information in both ID Tokens and Access Tokens so Spring Security can read it and set up a role-based access control (RBAC) mechanism.

NOTE In Polar Bookshop, the OAuth2 Client (Edge Service) and the OAuth2 Resource Servers (Catalog Service and Order Service) belong to the same system, but the same framework can be used when the OAuth2 Client is a third-party application. In fact, that was the original use case for OAuth2 and why it became so popular. Using OAuth2, services like GitHub or Twitter let you give third-party applications limited access to your account. For example, you could authorize a scheduling application to publish tweets on your behalf without exposing your Twitter credentials.

12.1.1 Token relay from Spring Cloud Gateway to other services

After a user successfully authenticates with Keycloak, Edge Service (the OAuth2 Client) receives an ID Token and an Access Token:

- *ID Token*—This represents a successful authentication event and includes information about the authenticated user.